BancaDigitalGT_ThreatModel

Propietario: Katherine Giron
Revisor: Jefe Informatica
Colaboradores: Arquitectura, Desarrollo, Seguridad
Release Date: Fri Oct 09 2026

Resumen Ejecutivo

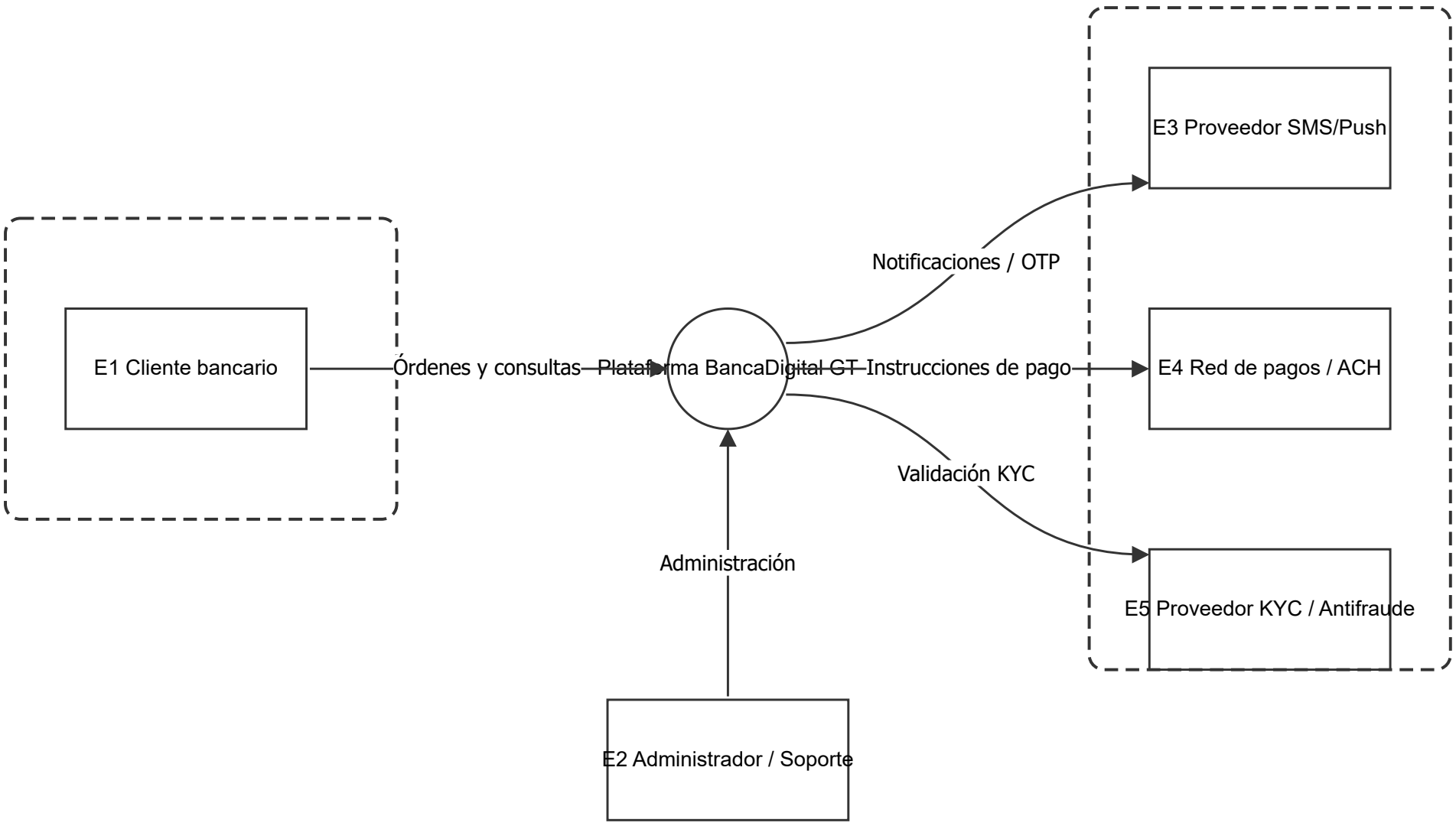
Descripción de alto nivel del sistema (high level system)

Modelo de amenazas de la plataforma de banca en línea y móvil BancaDigital GT

Resumen

Total amenazas	74
Total amenazas mitigadas	0
No Mitigadas	74
Abierto / Crítica Prioridad	26
Abierto / Alta Prioridad	38
Abierto / Prioridad Media	9
Abierto / Baja Prioridad	1

Nivel 0 - Contexto



Nivel 0 - Contexto

Plataforma BancaDigital GT (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
1	T-01 Toma de cuentas por credential stuffing y phishing	Spoofing	Crítica	Abierto		Atacante usa credenciales filtradas para autenticarse como cliente.	MFA fuerte (FIDO2/passkeys), bloqueo progresivo, detección de contraseñas filtradas.
2	T-03 Manipulación de monto o cuenta destino	Tampering	Crítica	Abierto		Alteración de parámetros de la orden de transferencia.	Validación de negocio en servidor, firma de orden, confirmación WYSIWYS.
3	T-04 BOLA/IDOR en API	Elevation of privilege	Crítica	Abierto		Acceso a cuentas de otros clientes cambiando identificadores.	Autorización por objeto, UUID, pruebas BOLA en CI.
4	T-08 DDoS y abuso de API	Denial of service	Crítica	Abierto		Inundación volumétrica o de capa 7 sin límites.	Anti-DDoS, WAF, rate limiting, autoescalado.

E1 Cliente bancario (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
5	T-02 SIM swap / interceptación de OTP por SMS	Spoofing	Crítica	Abierto		Suplantación del cliente ante la operadora para recibir OTP.	Reemplazar SMS por app autenticadora/passkeys; vinculación de dispositivo.

E2 Administrador / Soporte (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
6	T-10 Abuso de privilegios administrativos	Elevation of privilege	Alta	Abierto		Admin malicioso modifica datos de contacto y límites.	RBAC mínimo, cuatro ojos, PAM, MFA.

E3 Proveedor SMS/Push (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
7	T-18 Datos sensibles en SMS/push	Information disclosure	Media	Abierto		Fuga en el proveedor o en el canal.	Mensajes sin datos sensibles, contrato con el proveedor.

E4 Red de pagos / ACH (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
8	T-13 Callback/webhook falso de red de pagos	Spoofing	Alta	Abierto		Notificación falsa de confirmación de pago.	Verificación de firma, mTLS, lista de IP permitidas.

E5 Proveedor KYC / Antifraude (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

Órdenes y consultas (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

Administración (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

Notificaciones / OTP (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

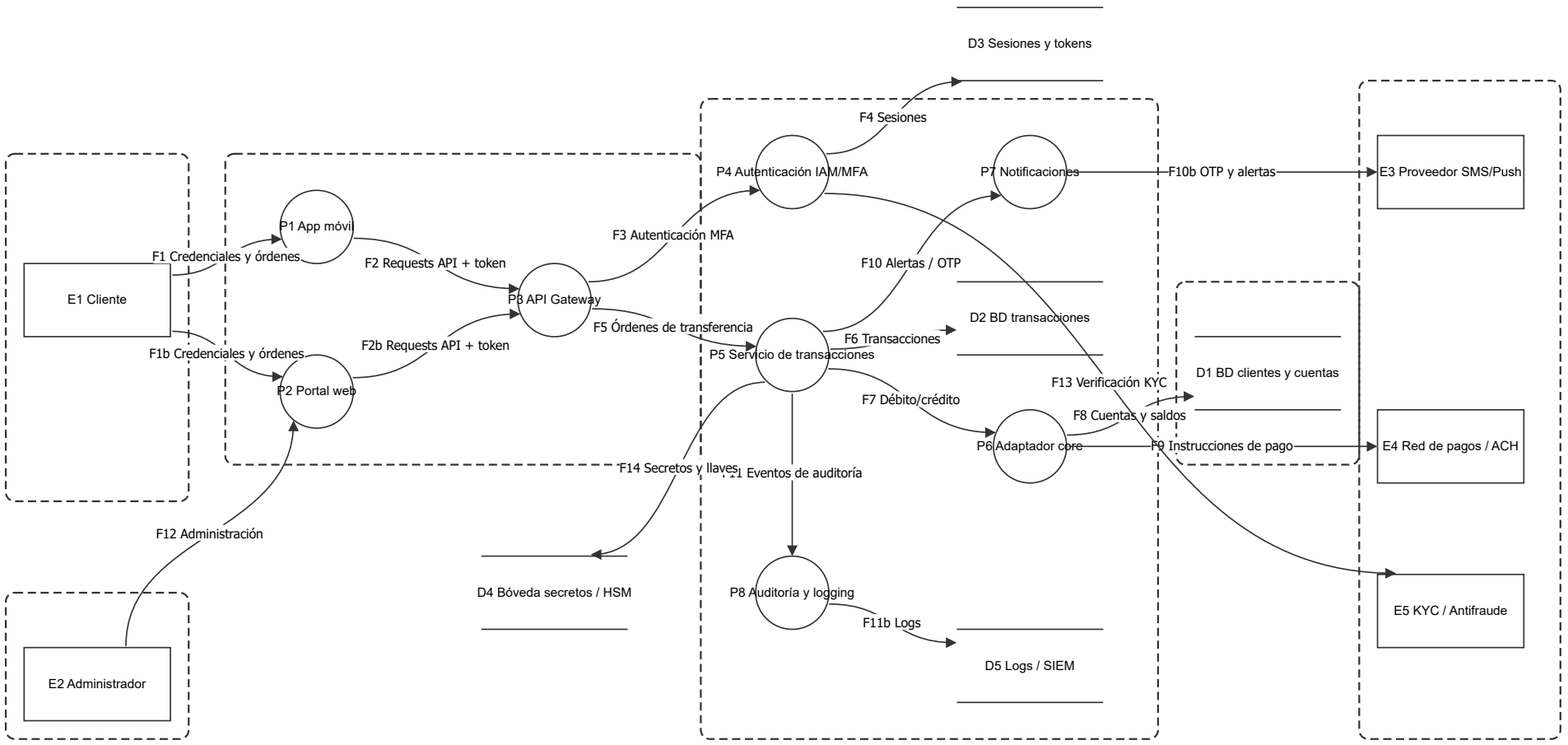
Instrucciones de pago (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

Validación KYC (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

Nivel 1 - Procesos principales



Nivel 1 - Procesos principales

E1 Cliente (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
9	T-02 SIM swap / interceptación de OTP por SMS	Spoofing	Crítica	Abierto		Suplantación del cliente ante la operadora para recibir OTP.	Reemplazar SMS por app autenticadora/passkeys; vinculación de dispositivo.

E2 Administrador (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
10	T-10 Abuso de privilegios administrativos	Elevation of privilege	Alta	Abierto		Admin malicioso modifica datos de contacto y límites.	RBAC mínimo, cuatro ojos, PAM, MFA.

E3 Proveedor SMS/Push (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

E4 Red de pagos / ACH (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
11	T-13 Callback/webhook falso de red de pagos	Spoofing	Alta	Abierto		Notificación falsa de confirmación de pago.	Verificación de firma, mTLS, lista de IP permitidas.

E5 KYC / Antifraude (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

P1 App móvil (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
12	T-02 SIM swap / interceptación de OTP por SMS	Spoofing	Crítica	Abierto		Suplantación del cliente ante la operadora para recibir OTP.	Reemplazar SMS por app autenticadora/passkeys; vinculación de dispositivo.
13	T-20 Ingeniería inversa y datos locales sin cifrar	Information disclosure	Media	Abierto		Dispositivo rooteado o app manipulada.	RASP, ofuscación, detección de root, cifrado local.

P2 Portal web (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
14	T-01 Toma de cuentas por credential stuffing y phishing	Spoofing	Crítica	Abierto		Atacante usa credenciales filtradas para autenticarse como cliente.	MFA fuerte (FIDO2/passkeys), bloqueo progresivo, detección de contraseñas filtradas.
15	T-09 Intercepción MitM sin certificate pinning	Information disclosure	Alta	Abierto		Captura de tráfico entre app y API.	TLS 1.3, certificate pinning, mTLS.
16	T-10 Abuso de privilegios administrativos	Elevation of privilege	Alta	Abierto		Admin malicioso modifica datos de contacto y límites.	RBAC mínimo, cuatro ojos, PAM, MFA.

P3 API Gateway (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
17	T-03 Manipulación de monto o cuenta destino	Tampering	Crítica	Abierto		Alteración de parámetros de la orden de transferencia.	Validación de negocio en servidor, firma de orden, confirmación WYSIWYS.
18	T-04 BOLA/IDOR en API	Elevation of privilege	Crítica	Abierto		Acceso a cuentas de otros clientes cambiando identificadores.	Autorización por objeto, UUID, pruebas BOLA en CI.
19	T-08 DDoS y abuso de API	Denial of service	Crítica	Abierto		Inundación volumétrica o de capa 7 sin límites.	Anti-DDoS, WAF, rate limiting, autoescalado.

P4 Autenticación IAM/MFA (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
20	T-01 Toma de cuentas por credential stuffing y phishing	Spoofing	Crítica	Abierto		Atacante usa credenciales filtradas para autenticarse como cliente.	MFA fuerte (FIDO2/passkeys), bloqueo progresivo, detección de contraseñas filtradas.

P5 Servicio de transacciones (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
21	T-03 Manipulación de monto o cuenta destino	Tampering	Crítica	Abierto		Alteración de parámetros de la orden de transferencia.	Validación de negocio en servidor, firma de orden, confirmación WYSIWYS.
22	T-07 Cliente niega transferencia	Repudiation	Alta	Abierto		Falta de no repudio sobre la orden.	Firma digital y sellado de tiempo de transacciones.

P6 Adaptador core (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
23	T-12 Alteración de mensajes hacia el core	Tampering	Media	Abierto		Inyección o modificación de mensajes del adaptador.	Firma de mensajes, validación de esquema, segmentación.
24	T-16 Saturación de colas y core	Denial of service	Alta	Abierto		Ráfagas saturan el adaptador del core.	Backpressure, circuit breakers, colas con límites.

P7 Notificaciones (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
25	T-18 Datos sensibles en SMS/push	Information disclosure	Media	Abierto		Fuga en el proveedor o en el canal.	Mensajes sin datos sensibles, contrato con el proveedor.

P8 Auditoría y logging (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
26	T-15 Logs alterables o trazabilidad incompleta	Repudiation	Alta	Abierto		Eliminación o alteración de evidencia.	Almacenamiento WORM, hash de logs, SIEM.

D1 BD clientes y cuentas (Dispositivo de almacenamiento)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
27	T-05 Exfiltración de BD de clientes	Information disclosure	Alta	Abierto		Inyección SQL o credenciales de BD filtradas.	Consultas parametrizadas, mínimo privilegio, cifrado de columnas, DAM.
28	T-21 Consultas costosas a BD	Denial of service	Baja	Abierto		Degradación por consultas pesadas.	Límites de consulta, índices, réplicas de lectura.

D2 BD transacciones (Dispositivo de almacenamiento)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
29	T-06 Alteración de registros de transacciones por insider	Tampering	Alta	Abierto		DBA o desarrollador modifica datos directamente.	PAM, separación de funciones, hash encadenado, conciliación diaria.
30	T-07 Cliente niega transferencia	Repudiation	Alta	Abierto		Falta de no repudio sobre la orden.	Firma digital y sellado de tiempo de transacciones.

D3 Sesiones y tokens (Dispositivo de almacenamiento)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
31	T-17 Robo de tokens / JWT mal validado	Tampering	Crítica	Abierto		Reutilización o forja de tokens de sesión.	Tokens cortos con rotación, validación estricta, revocación.

D4 Bóveda secretos / HSM (Dispositivo de almacenamiento)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
32	T-11 Secretos y llaves expuestos	Information disclosure	Alta	Abierto		Secretos en repositorios, imágenes o variables de entorno.	Vault/HSM, escaneo de secretos en CI/CD, rotación.

D5 Logs / SIEM (Dispositivo de almacenamiento)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
33	T-14 Logs con datos sensibles	Information disclosure	Alta	Abierto		PAN, tokens o PII en texto claro en logs.	Enmascarado, tokenización, control de acceso a logs.
34	T-15 Logs alterables o trazabilidad incompleta	Repudiation	Alta	Abierto		Eliminación o alteración de evidencia.	Almacenamiento WORM, hash de logs, SIEM.

F1 Credenciales y órdenes (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
35	T-09 Intercepción MitM sin certificate pinning	Information disclosure	Alta	Abierto		Captura de tráfico entre app y API.	TLS 1.3, certificate pinning, mTLS.

F1b Credenciales y órdenes (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
36	T-09 Intercepción MitM sin certificate pinning	Information disclosure	Alta	Abierto		Captura de tráfico entre app y API.	TLS 1.3, certificate pinning, mTLS.

F2 Requests API + token (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
37	T-17 Robo de tokens / JWT mal validado	Tampering	Crítica	Abierto		Reutilización o forja de tokens de sesión.	Tokens cortos con rotación, validación estricta, revocación.
38	T-04 BOLA/IDOR en API	Elevation of privilege	Crítica	Abierto		Acceso a cuentas de otros clientes cambiando identificadores.	Autorización por objeto, UUID, pruebas BOLA en CI.

F2b Requests API + token (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
39	T-17 Robo de tokens / JWT mal validado	Tampering	Crítica	Abierto		Reutilización o forja de tokens de sesión.	Tokens cortos con rotación, validación estricta, revocación.

F3 Autenticación MFA (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
40	T-01 Toma de cuentas por credential stuffing y phishing	Spoofing	Crítica	Abierto		Atacante usa credenciales filtradas para autenticarse como cliente.	MFA fuerte (FIDO2/passkeys), bloqueo progresivo, detección de contraseñas filtradas.

F4 Sesiones (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
41	T-17 Robo de tokens / JWT mal validado	Tampering	Crítica	Abierto		Reutilización o forja de tokens de sesión.	Tokens cortos con rotación, validación estricta, revocación.

F5 Órdenes de transferencia (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
42	T-03 Manipulación de monto o cuenta destino	Tampering	Crítica	Abierto		Alteración de parámetros de la orden de transferencia.	Validación de negocio en servidor, firma de orden, confirmación WYSIWYS.

F6 Transacciones (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
43	T-06 Alteración de registros de transacciones por insider	Tampering	Alta	Abierto		DBA o desarrollador modifica datos directamente.	PAM, separación de funciones, hash encadenado, conciliación diaria.

F7 Débito/crédito (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
44	T-12 Alteración de mensajes hacia el core	Tampering	Media	Abierto		Inyección o modificación de mensajes del adaptador.	Firma de mensajes, validación de esquema, segmentación.

F8 Cuentas y saldos (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
45	T-05 Exfiltración de BD de clientes	Information disclosure	Alta	Abierto		Inyección SQL o credenciales de BD filtradas.	Consultas parametrizadas, mínimo privilegio, cifrado de columnas, DAM.

F9 Instrucciones de pago (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
46	T-13 Callback/webhook falso de red de pagos	Spoofing	Alta	Abierto		Notificación falsa de confirmación de pago.	Verificación de firma, mTLS, lista de IP permitidas.

F10 Alertas / OTP (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F10b OTP y alertas (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
47	T-18 Datos sensibles en SMS/push	Information disclosure	Media	Abierto		Fuga en el proveedor o en el canal.	Mensajes sin datos sensibles, contrato con el proveedor.

F11 Eventos de auditoría (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
48	T-15 Logs alterables o trazabilidad incompleta	Repudiation	Alta	Abierto		Eliminación o alteración de evidencia.	Almacenamiento WORM, hash de logs, SIEM.

F11b Logs (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
49	T-14 Logs con datos sensibles	Information disclosure	Alta	Abierto		PAN, tokens o PII en texto claro en logs.	Enmascarado, tokenización, control de acceso a logs.

F12 Administración (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
50	T-10 Abuso de privilegios administrativos	Elevation of privilege	Alta	Abierto		Admin malicioso modifica datos de contacto y límites.	RBAC mínimo, cuatro ojos, PAM, MFA.

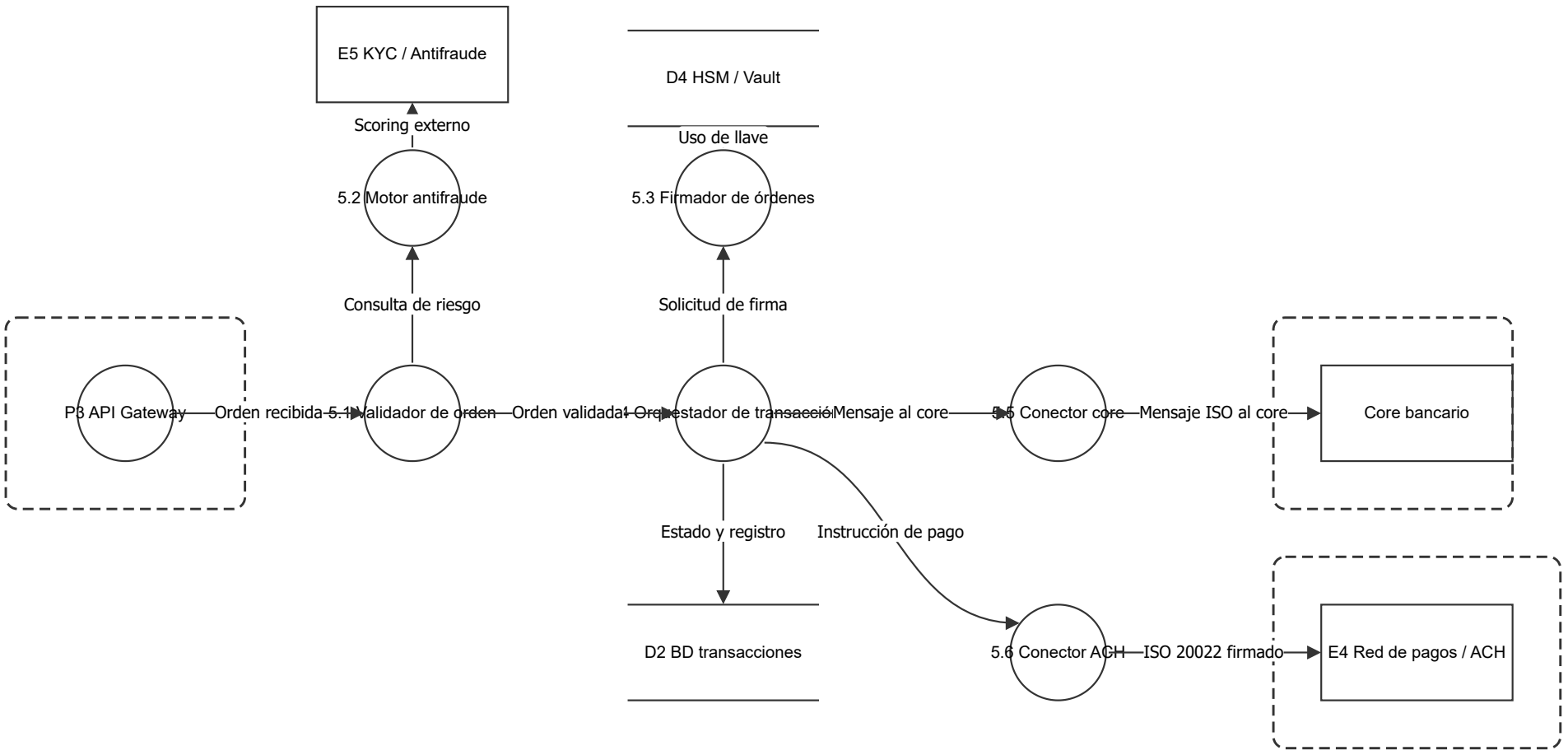
F13 Verificación KYC (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

F14 Secretos y llaves (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
51	T-11 Secretos y llaves expuestos	Information disclosure	Alta	Abierto		Secretos en repositorios, imágenes o variables de entorno.	Vault/HSM, escaneo de secretos en CI/CD, rotación.

Nivel 2 - Flujo de transferencia e integración bancaria



Nivel 2 - Flujo de transferencia e integración bancaria

P3 API Gateway (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
52	T-03 Manipulación de monto o cuenta destino	Tampering	Crítica	Abierto		Alteración de parámetros de la orden de transferencia.	Validación de negocio en servidor, firma de orden, confirmación WYSIWYS.
53	T-08 DDoS y abuso de API	Denial of service	Crítica	Abierto		Inundación volumétrica o de capa 7 sin límites.	Anti-DDoS, WAF, rate limiting, autoescalado.

5.1 Validador de orden (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
54	T-03 Manipulación de monto o cuenta destino	Tampering	Crítica	Abierto		Alteración de parámetros de la orden de transferencia.	Validación de negocio en servidor, firma de orden, confirmación WYSIWYS.

5.2 Motor antifraude (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
55	T-01 Toma de cuentas por credential stuffing y phishing	Spoofing	Crítica	Abierto		Atacante usa credenciales filtradas para autenticarse como cliente.	MFA fuerte (FIDO2/passkeys), bloqueo progresivo, detección de contraseñas filtradas.

5.3 Firmador de órdenes (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
56	T-11 Secretos y llaves expuestos	Information disclosure	Alta	Abierto		Secretos en repositorios, imágenes o variables de entorno.	Vault/HSM, escaneo de secretos en CI/CD, rotación.

5.4 Orquestador de transacción (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
57	T-07 Cliente niega transferencia	Repudiation	Alta	Abierto		Falta de no repudio sobre la orden.	Firma digital y sellado de tiempo de transacciones.

5.5 Conector core (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
58	T-12 Alteración de mensajes hacia el core	Tampering	Media	Abierto		Inyección o modificación de mensajes del adaptador.	Firma de mensajes, validación de esquema, segmentación.
59	T-16 Saturación de colas y core	Denial of service	Alta	Abierto		Ráfagas saturan el adaptador del core.	Backpressure, circuit breakers, colas con límites.

5.6 Conector ACH (Proceso)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
60	T-13 Callback/webhook falso de red de pagos	Spoofing	Alta	Abierto		Notificación falsa de confirmación de pago.	Verificación de firma, mTLS, lista de IP permitidas.

D2 BD transacciones (Dispositivo de almacenamiento)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
61	T-06 Alteración de registros de transacciones por insider	Tampering	Alta	Abierto		DBA o desarrollador modifica datos directamente.	PAM, separación de funciones, hash encadenado, conciliación diaria.

D4 HSM / Vault (Dispositivo de almacenamiento)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
62	T-11 Secretos y llaves expuestos	Information disclosure	Alta	Abierto		Secretos en repositorios, imágenes o variables de entorno.	Vault/HSM, escaneo de secretos en CI/CD, rotación.

E5 KYC / Antifraude (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

E4 Red de pagos / ACH (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
63	T-13 Callback/webhook falso de red de pagos	Spoofing	Alta	Abierto		Notificación falsa de confirmación de pago.	Verificación de firma, mTLS, lista de IP permitidas.

Core bancario (Actor)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

Orden recibida (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
64	T-03 Manipulación de monto o cuenta destino	Tampering	Crítica	Abierto		Alteración de parámetros de la orden de transferencia.	Validación de negocio en servidor, firma de orden, confirmación WYSIWYS.

Consulta de riesgo (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

Scoring externo (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones

Orden validada (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
65	T-03 Manipulación de monto o cuenta destino	Tampering	Crítica	Abierto		Alteración de parámetros de la orden de transferencia.	Validación de negocio en servidor, firma de orden, confirmación WYSIWYS.

Solicitud de firma (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
66	T-11 Secretos y llaves expuestos	Information disclosure	Alta	Abierto		Secretos en repositorios, imágenes o variables de entorno.	Vault/HSM, escaneo de secretos en CI/CD, rotación.

Uso de llave (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
67	T-11 Secretos y llaves expuestos	Information disclosure	Alta	Abierto		Secretos en repositorios, imágenes o variables de entorno.	Vault/HSM, escaneo de secretos en CI/CD, rotación.

Estado y registro (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
68	T-06 Alteración de registros de transacciones por insider	Tampering	Alta	Abierto		DBA o desarrollador modifica datos directamente.	PAM, separación de funciones, hash encadenado, conciliación diaria.
69	T-07 Cliente niega transferencia	Repudiation	Alta	Abierto		Falta de no repudio sobre la orden.	Firma digital y sellado de tiempo de transacciones.

Mensaje al core (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
70	T-12 Alteración de mensajes hacia el core	Tampering	Media	Abierto		Inyección o modificación de mensajes del adaptador.	Firma de mensajes, validación de esquema, segmentación.

Mensaje ISO al core (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
71	T-12 Alteración de mensajes hacia el core	Tampering	Media	Abierto		Inyección o modificación de mensajes del adaptador.	Firma de mensajes, validación de esquema, segmentación.
72	T-16 Saturación de colas y core	Denial of service	Alta	Abierto		Ráfagas saturan el adaptador del core.	Backpressure, circuit breakers, colas con límites.

Instrucción de pago (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
73	T-13 Callback/webhook falso de red de pagos	Spoofing	Alta	Abierto		Notificación falsa de confirmación de pago.	Verificación de firma, mTLS, lista de IP permitidas.

ISO 20022 firmado (Flujo de datos)

Número	Título	Tipo	Prioridad	Estado	Puntuación	Descripción	Mitigaciones
74	T-13 Callback/webhook falso de red de pagos	Spoofing	Alta	Abierto		Notificación falsa de confirmación de pago.	Verificación de firma, mTLS, lista de IP permitidas.